Security self-assessment

Zishi, 2026 Shenzhen International FinTech Competition, International Track, Topic F. Structured on the four headings of the official template (international-security-self-assessment-en): 01 Permission Model, 02 Security Tests, 03 Data and Privacy, 04 Known Risks. Every claim names the file that implements it. Where something is a demo shortcut, it says so.

01 Permission Model

Roles, operations and permission boundaries

Who can do what. Four tiers, enforced in `PolicyEngine.evaluate()` (`web/src/engine/policy.ts`) on every signed intent, and again on chain by the contracts.

Tier	Who	Can	Cannot
L0 read	Anyone, the model	Read prices, balances, messages	Move anything
L1 draft	The model	Write one sentence of explanation	Name a payee or an amount; hold a key
L2 engine allow	The machine key, through 21 rule lines	Sign typed intents that pass every line: signature, replay, amount, provenance, allowlist, lookalike, instalment payee, per transaction cap, reserve rule	Raise its own cap, add a payee, spend outside the allowlist
L3 operator	The pilot's operator key, behind the physical button step	`set_cap`, `top_up`, one displayed action at a time	Move the lease rate outside the signed band (`Lease.setRate`)

Keys. Seven actor keys with separate roles (machine, operator, requester, lender, vendor, hunter, oracle). The model process holds none. In the deployed app every actor key is generated from a secure random source when the server instance starts, kept only in memory, never logged and never sent to the browser; only the addresses are public (`GET /api/keys`). A fixed derivation from public labels exists only behind `ZISHI_DETERMINISTIC_KEYS=1`, used by the tests, the replay check and evidence reproduction so seeded runs hash identically. Production keys: the machine key in the drone's secure element, the operator key in a hardware device, the lender key in the lessor's HSM, the vendor key in our HSM, rotation through `Bond.register` by the operator.

Routes that act. Real chain mode (`/api/run`) and the L3 button (`/api/button`) require the demo token (header `x-zishi-demo`, compared with the `DEMO_TOKEN` deployment secret; unset means always refused). A public visitor gets the simulated chain and a refused button. The judge console (`/api/judge`) caps the body at 64 KiB and never touches a wallet.

On chain. `Bond.slashByProof` reads every fact from the signed intent, `IntentLog`, `JobBoard` and `Lease`; the reporter only names the rule and must be a party of the job (hunters only on shadow jobs). `Bond.topUp` is operator only. Each intent hash can be used once (spent set).

Trust boundaries.

Boundary	What crosses it	Defence
Counterparty to agent	Messages, invoices, tool results	Escaped and framed as data; judge gate (rules plus classifier) before the agent reads it

Boundary	What crosses it	Defence
Model to engine	One sentence	Number grounding check, template fallback, no key in the model process
Agent to wallet	Typed EIP-712 intents	Policy engine, every rule a line; allow or nothing moves
Engine to chain	Transactions	Intent hash committed to `IntentLog` first; contracts re-check rules; slash only by proof
Operator to engine	Cap and top up	Operator only rule, button step, demo token on the route, band check
Learned components to engine	Risk score, anomaly score, plan, strategy numbers	Scores can only add a hold; plan re-checked per job by `economics()`; the ratchet cannot cross the reserve rule

Confirmation, verification and rollback mechanisms

Mechanism	What it does	Where
Typed signature on every intent	Every action is an EIP-712 intent; the signer is recovered and must be the actor's key, the hash must be unspent	`policy.ts` signature and replay lines, `Bond.sol` spent set
Policy before money	21 rule lines run before anything moves; a failed line means nothing moves	`PolicyEngine.evaluate()`
Human confirmation for L3	Cap and top up changes need the operator's button step, one displayed action at a time, behind the demo token	`/api/button`, operator only rule
Farmer confirmation	A fee is released only after the verifier confirms the job on chain	`JobBoard.confirm`
24 hour hold and flag	Part of every fee is held; the farmer can flag bad work for a human arbiter inside the window	`JobBoard.flag`, `releaseHold`
Oracle hold	An implausible or incomplete flight log keeps the fee locked instead of paying	`oracle.ts`, scenario hold branch
Rollback by contract	A job that cannot start is cancelled on chain and the farmer gets the whole fee back (`JobBoard.cancel`); a failed call is retried with a fresh nonce, a revert goes to compensation	`settle.ts` recovery states, drills in `web/evidence/fisco/recovery-*.json`
Freeze	The lender can freeze the lease on a slash or tampered data	`Lease.freeze`
Audit head	The hash chained event log's head is committed to the FISCO IntentLog at the end of each real run	`anchorAuditHead` in `chain.ts`

Threat model (STRIDE), per asset.

Threat	Example against Zishi	Control	Evidence
Spoofing	Someone signs as the machine, operator or lender	Keys random per server instance and in memory; EIP-712 typed signatures recovered and checked on every intent; on chain `slashByProof` recovers the agent's signature	`keys.ts`, `policy.ts` signature line, `Bond.sol`, `GET /api/keys` (addresses only)

Threat	Example against Zishi	Control	Evidence
Tampering	A payee or amount edited after signing; a flight log edited; the event log edited	Signature covers every field; spent set; Kalman track and conformal score hold implausible logs; hash chained event log, its head committed to the FISCO IntentLog at the end of each real run	attack cases 40, 14; `oracle.ts`; `replay/log.ts`; `auditTx` on `chain_head`
Repudiation	The agent denies an intent it signed; a lender denies a slash	Intent hash committed before the decision; V2 log accepts only the job's agent; every transaction re-verifiable	`IntentLogV2.sol`, `pnpm verify:all` (329 of 329)
Information disclosure	Field locations or a farmer's name on a public chain	Hashes only on chain; full intents only to the job's parties; no telemetry stored	`IntentLog.sol`, section 03
Denial of service	A visitor floods runs; a pilot drains the vendor bond with fake reports	Per IP limiter and one run at a time per IP; vendor penalty fixed with a daily cap; hunters only on shadow jobs	`ratelimit.ts`, `Bond.sol` dailyCap, attack case 52
Elevation of privilege	Injected text raises the cap; a visitor presses the L3 button	Model holds no key and has no rule changing intent kind; operator only rule; `/api/button` needs the demo token	`policy.ts`, `/api/button` 401, attack set

Web layer. Security headers on every route: frame-ancestors none, X-Frame-Options DENY, nosniff, strict referrer policy, a Permissions-Policy that denies camera, microphone, location and payment, HSTS from the host. Inputs to `/api/ask`, `/api/run-custom` and `/api/judge` are validated and size capped; every route that can act on a chain needs the demo token or runs on the no-value FISCO test chain with a fresh key per run.

02 Security Tests

Prompt injection, social engineering, privilege escalation and failure recovery tests

Test	What it covers	Where	Result
Attack set	52 cases at three layers: message (injection, impersonation, payee in text, Chinese variants), policy (over cap, off allowlist, lookalike, replay, forged signer), contract (slash rules, not a party, proof reuse, not in log)	`web/src/engine/attacks.ts`, run in `pnpm test` and on every load of the Evidence page	52 of 52 blocked by the full pipeline; see `docs/RED_TEAM.md` (generated)
Benign set	Ordinary requests through the same gate must pass	same	7 of 7 pass

Test	What it covers	Where	Result
Classifier held out	Injection classifier on a held out split disjoint from training; the attack texts are not in the training corpus	`web/src/engine/ml/gate.ts`, `docs/EVALUATION.md`	87 held out: precision 100% (26 of 26, interval 87.1 to 100), recall 81.3% (26 of 32, 64.7 to 91.1), false alarm 0 of 55 (0 to 6.5). On the 52 attack texts, never trained on: the classifier alone holds 13; the full pipeline blocks 52
Flight log oracle	Tamper detection and false alarms on synthetic flights	`web/src/engine/ml/plausibility.ts`, `oracle.ts`, `docs/EVALUATION.md`	500 synthetic held out flights, seed 7331: detection 72 of 72 (94.9 to 100%), false alarm 13 of 428 honest (3.0%, 1.8 to 5.1%)
Fail safe on missing data	A missing or degraded sensor channel holds the fee instead of imputing it	`oracle.ts`, `selfcheck.ts`	Held, with a reason
Solidity tests	Contract rules, fuzzed amounts, nonces and payees; contract layer attacks ported to Solidity; Lease tests	`contracts/test/*.t.sol`, CI	84 tests, all passing; the 15 contract layer attacks run against Solidity, not only the TypeScript mirrors
Full job on chain	Fee locked, confirmed, instalment paid, slash by proof, title at zero, against the deployed contracts	`contracts/script/`, `contracts/deployments/*-fulljob.json`, `docs/EXECUTION_EVIDENCE.md`	Base Sepolia: 9 of 9 contract calls succeeded, value moved; the same job on FISCO BCOS
Evidence verification	Every transaction the repository claims re-fetched from its chain, intent hashes decoded from calldata	`pnpm verify:all`, `docs/results/receipts.json`	329 of 329 receipts verified
Replay and tamper	Two runs on one seed end on the same hash chain head; an edited entry is caught at its index	`web/src/engine/replay`, `selfcheck.ts`	Caught
Static analysis	Slither 0.11.6 over every contract, v1 and v2	`docs/SECURITY_SCAN.md`, `web/scripts/security-scan.sh`	42 findings triaged: 0 true issues of medium or higher; v1 Lease.pay reentrancy accepted with reason (balance cut before the call)
Dependencies	`pnpm audit` on the app	`docs/SECURITY_SCAN.md`	0 vulnerabilities in production dependencies; one dev only lint dependency without a patched version, accepted

Test	What it covers	Where	Result
Secrets	gitleaks over the whole git history and the working tree	`docs/SECURITY_SCAN.md`	0 leaks; keys live only in gitignored local files and deployment secrets
Failure recovery	Retry then success, revert then compensation, retries exhausted; drilled on chain with `ZISHI_FAULT=confirm-once` and `start-revert`	`selfcheck.ts` recovery check, `web/evidence/fisco/recovery-*.json`	Both drills passed; the farmer got the whole fee back by `JobBoard.cancel`
Route auth	The L3 button and real mode refuse without the demo token	`selfcheck.ts`	Refused

Run all of it: `cd web && pnpm test && pnpm lint`, `cd contracts && forge test`.

03 Data and Privacy

Data provenance, consent, minimisation, storage and deletion

Aspect	In this build	In production
Provenance	Job offers, flight logs and messages are synthetic and labelled; the out of domain oracle check uses 92 public PX4 flight logs (CC-BY, credited by log id); the FATE data is seeded and synthetic	Signed flight logs from the drone's secure element, job terms signed by the farmer
Consent	No real person's data is processed	Consent in the job terms for the parties of the job; the pilot consents to credit scoring by the lessor
Minimisation	On chain only hashes, addresses and amounts in demo units; the model receives only the numbers of one decision	Same; field coordinates never leave the parties
Storage	Nothing personal is stored; uploaded jobs are processed in memory for one run; the run log lives in server memory; committed evidence files hold synthetic data and hashes only	Job data with the parties and the lessor, under the lessor's retention policy
Deletion	In memory logs end with the server instance; evidence files are synthetic	Deletion on request off chain; on chain hashes cannot be reversed to personal data

On chain, hashes only. `IntentLog` stores an intent hash, a job id hash, the committing address and a time. No field location, telemetry, name or phone number goes on chain. The full intent is delivered only to the parties of the job (farmer, pilot, lender, vendor). This is how the design meets the Personal Information Protection Law (PIPL) and the Data Security Law: field coordinates can be personal or business data, so they stay among the parties.

In the demo. All people, fields and flights are synthetic and say so. The FATE credit experiment uses seeded synthetic pilots; three lenders train one model and no lender's rows leave its own process (`fate/README.md`). No raw telemetry is stored by the app; the event log keeps hashes and decisions.

Automated decisions (PIPL Article 24). Every money decision is made by code against written rules, and the person affected can ask why: the ask the agent panel explains a declined job from the engine's own numbers, offers the alternative that would clear the rule, and names the rule and who can change it. A

held flight log or a slash goes to a human arbiter path (the 24 hour hold and `JobBoard.flag`). The model only writes explanations, labelled model or template.

Impact assessment (PIPL Articles 55 and 56), in short.

Question	Answer
What personal information	A farmer's name and field location in the job terms; the pilot's identity with the lessor. No biometrics, no precise personal location on chain
Purpose and necessity	Pricing and confirming a spraying job, repaying a lease; nothing else
Where it lives	With the parties of the job; only hashes on chain; the demo stores no personal data and processes uploaded jobs in memory for the run only
Automated decision impact	Job accepted or declined, fee held or paid, bond slashed: explained on request, rule based, with a human dispute path
Security measures	Section 01 and 02; keys per server instance; signed intents; audit head on the consortium ledger
Cross border	None needed: production runs on a mainland consortium chain and mainland payment rails; the demo's public test chain carries hashes and demo units only

Generative AI. The model writes explanations only, through free models on OpenRouter; every number it writes must appear in the facts or the template is used, and each text is labelled with its source. A mainland deployment would use a model service that has completed the filing required under the Interim Measures for the Management of Generative AI Services (2023).

Regulatory map (our reading, to be confirmed by the sandbox lessor's counsel).

Area	Rule	How Zishi fits
Financial leasing (融资租赁)	NFRA: Measures for the Administration of Financial Leasing Companies (金融租赁公司管理办法, 2024); interim measures for financing lease companies (融资租赁公司监督管理暂行办法, 2020)	A licensed leasing company is the lessor and lender of record. Zishi services the contract (repayment per mu inside a signed band, freeze, title at zero); it does not lend
Payments	PBoC: Regulations on Non-bank Payment Institutions (非银行支付机构监督管理条例, 2024)	Fees settle through a licensed bank or payment institution, or e-CNY; the chain records, it does not custody customer funds
Crypto	PBoC notice on virtual currency trading (2021)	No public token for mainland users. Testnet units here are evidence only; production uses a consortium chain (FISCO BCOS) with bank money
Drone operations	CAAC: Interim Regulations on the Flight Management of Unmanned Aircraft (无人驾驶航空器飞行管理暂行条例, 2024) and CCAR-92	The pilot holds the operator licence and the operation certificate, the drone is real name registered, third party liability insurance is in force. The job terms carry these as preconditions; Zishi does not fly the drone
Personal data	PIPL, Data Security Law	Hashes on chain, consent in the job terms, details among the parties
Hong Kong	HKMA (stored value and payments), SFC (virtual asset activities), PDPO (personal data)	A Hong Kong rollout keeps the same split: licensed lessor, licensed payment rail, no token offered to the public, personal data among the parties

04 Known Risks

Risk, impact, mitigation and planned improvement

Risk	Impact and mitigation today	Where	Planned improvement
`IntentLog.commit` can be front run	Fixed in V2 on FISCO BCOS, open on the Base Sepolia v1 deployment. V2: `IntentLogV2` accepts a commit only from the agent JobBoard lists for the job and keys entries by (agent, hash); `BondV2` also slashes an agent that skipped the commit on a job it ran. Demonstrated on FISCO (`contracts/deployments/fisco-v2.json`), 16 Foundry tests. In v1: `commit` is permissionless and first writer wins per hash with `agentOf = msg.sender`. Anyone who sees an intent hash can commit it first, and `slashByProof` then fails "not in log". A compromised agent can also simply not commit. Mitigation today: the engine commits before the policy engine decides, and parties receive the full intent	`contracts/src/IntentLog.sol`	Redeploy V2 on Base Sepolia
Actor keys in software	Random per server instance and in memory (fixed only for tests and replays); still software keys on one server, not a secure element per actor	`keys.ts`, `/api/keys`	Per actor keys in secure hardware, one signer per party
Engine mirrors on Base	On FISCO the engine settles every money event on the deployed contracts; on Base Sepolia it calls IntentLog and anchors money events to spare the small funded wallet, with one full job run against the deployed contracts there	`web/src/engine/contracts.ts`, `contracts/script/`	Engine calls the contracts through their ABIs; mirrors become the test oracle
Rate limiting	Best effort, in memory per serverless instance	`ratelimit.ts`	Per key quotas behind auth
Oracle calibration	Calibrated on synthetic spraying flights. Checked out of domain on 92 real PX4 multirotor mission flights (public logs, CC-BY): the synthetic calibration holds all 92 (battery per mu and altitude variance differ from spraying physics). Recalibrated on a held out split of the real flights (28 fit, 36 calibrate, 28 test): 7.1% false alarm (2 of 28, interval 2.0 to 22.6) and 81.4% detection at a 10% target. A false alarm holds the fee for review, it never slashes	`docs/results/realflights.json`, `pnpm realflights`	Recalibrate per airframe on real spraying logs (about 50 or more calibration flights), altitude variance over spray passes only

Risk	Impact and mitigation today	Where	Planned improvement
Classifier corpus	Handwritten by the team; the held out split is disjoint but written by the same people	`ml/corpus.ts`	Held out set written by someone outside the team, then real held messages
Farmer and pilot collusion	A stated rule, not code	`TECHNICAL.md`	Credit counts a job only when farmer and pilot differ, track and confirmation agree, and the fee came from an address with history
Chain reorg	`RealChain` waits for a receipt and two confirmations on Base	`chain.ts`	Consortium chain finality (FISCO BCOS PBFT is final at commit)
FISCO BCOS	Running as a single local node in Docker with receipts in `docs/FISCO_EVIDENCE.md`; the public demo reaches it through a tunnel while the node is up. FISCO block time is in milliseconds, so JobBoard windows need a unit fix there	`contracts/script/fisco.sh`	A node run by the lessor in a consortium group
Public FISCO RPC	The demo's FISCO node is reachable through a tunnel so the public app can use it; anyone could send transactions to this no value test chain or try to slow it. The deployer key there holds only test balance, each public run signs with a fresh key, and the app falls back to the labelled simulation if the node does not answer in 3 seconds	`chain.ts` publicFisco, `fisco_rpc_proxy.py`	A consortium node inside the lessor's network, RPC behind mutual TLS and an allowlist
Compliance is designed, not licensed	The lessor, payment rail and filings are mapped (section 03) but no licensed partner has signed off	`SELF_ASSESSMENT.md` 03	A sandbox agreement with one licensed lessor
Physical damage	Out of scope; the bonds cover rule breaks only	`JobBoard.flag` hold	Drone insurance plus a human dispute path

Risk	Impact and mitigation today	Where	Planned improvement
Model outage or cost	Free models only: ids must end in `:free` or they are dropped, so the key cannot route to a paid model; at most 10 calls a minute; no key, a 9 second timeout or an error means labelled template text; the model never moves money	`model.ts`, `agents.ts`	A contracted model with an SLA, same fallback